

(피드백 여기서 수정) SW아키텍처 - 전자결재 중간발표 보고서 (김승겸, 노현정, 이승규) - 피드백
SW아키텍처 - 전자결재 (김승겸, 노현정, 이승규)

1. 프로젝트 개요

본 프로젝트는 사내 전자결재 업무의 효율성과 보안을 개선하는 **전자결재 시스템** 설계를 목표로 한다.

1주차 발표에서는 하이웍스, 다우오피스, 네이버웍스의 전자결재 기능을 벤치마킹해 결재 상신, 결재선 지정, 상신 후 수정, 회수, 승인, 반려, 문서함 검색 기능을 도출했다. 기존 1주차 자료에서는 결재 양식별 직위·직책 템플릿, 제한적 즉시 수정, 리스크 기반 차등 승인, 특정 단계 반려, OCR 기반 문서 검색이 핵심 설계 방향으로 제시되었다.

2주차 보고서는 수업 가이드라인 요구사항에 맞춰 **유스케이스 명세서, ERD 및 데이터 사전, 아키텍처 다이어그램, ADR, API 명세, 초기 와이어프레임, 추적성 체크리스트**를 작성한다.

2. 1주차 피드백 반영 요약

피드백	기존 설계 문제	2주차 반영
고위험 문서마다 2FA 인증	보안은 높지만 결재자의 업무 흐름이 끊김	고위험 문서는 본문 확인과 세션 인증 상태를 검증하며, 세션 인증 만료나 위험 접속 시 재인증한다
관리자 역할의 비현실성	관리자가 모든 부서의 양식과 고 위험 여부를 직접 관리해야 함	전체 관리자와 부서관리자로 구분하고, 부서 관리자가 양식·리스크 기준·결재선 템플릿 을 관리한다
지능형 결재선 추천의 불명확성	추천 근거와 책임이 불명확함	직위·직책 기반 결재선 템플릿으로 수정

3. 핵심 유스케이스 선정

수업 가이드라인에 따라 **핵심 유스케이스 3~5개**를 명세하므로, 본 보고서에서는 전자결재 시스템의 핵심 흐름을 대표하는 **5개 유스케이스**만 상세 명세한다.

유스케이스 ID	유스케이스명	주요 액터	관련 핵심 기능	우선순위
UC-DOC-01	결재 문서 작성 및 상신	기안자	문서 작성, 결재선 템플릿, 상신	Must

UC-DOC-02	상신 후 즉시 수정 및 회수	기안자	즉시 수정, 회수, 임시저장함 이동	Must
UC-APP-01	결재 승인	결재자	일반 승인, 고위험 승인, 전결	Must
UC-APP-02	결재 반려	결재자	반려 사유, 특정 단계 반려	Must
UC-ADMIN-01	부서별 결재 양식 및 리스크 기준 관리	부서 관리자	양식, 고위험 기준, 결재선 템플릿 관리	Must

4. 유스케이스 명세서

4.1 UC-DOC-01 결재 문서 작성 및 상신

항목	내용
유스케이스명	결재 문서 작성 및 상신
ID	UC-DOC-01
주요 액터	기안자
보조 액터	결재선 템플릿 시스템, OCR 시스템, 알림 시스템, 보안 필터 시스템
우선순위	Must

사전 조건

- 사용자는 로그인 상태여야 한다.
- 사용자는 결재 문서 작성 권한을 가져야 한다.
- 결재 양식이 시스템에 등록되어 있어야 한다.
- 결재 양식에는 직위·직책 기반 결재선 템플릿이 연결되어 있어야 한다.

사후 조건

- approval_documents 에 결재 문서가 생성된다.
- approval_lines 에 실제 결재선이 생성된다.
- 문서 상태는 IN_PROGRESS 가 된다.

- 알림 시스템(Message Queue)에 첫 번째 결재자를 위한 알림 생성 이벤트가 정상적으로 등록된다.
- 첨부파일이 있으면 attachments에 저장된다.

불변식

- 결재자는 최소 1명 이상이어야 한다.
- 동일 사용자는 동일 역할에 중복 지정할 수 없다.
- 결재선 검증을 통과하지 못한 문서는 상신할 수 없다.
- 문서 작성자와 결재선에 포함된 사용자만 문서에 접근할 수 있다.
- 문서 상신 이후 기안자의 부서가 변경되더라도, 해당 문서의 결재선은 상신 시점의 조직 체계 및 결재 권한을 유지해야 한다.
- 합의자는 문서를 최종 승인할 순 없지만, 반려 시 해당 결재 프로세스 전체를 즉시 중단시킬 수 있다.

기본 흐름

1. 기안자가 대시보드에서 결재 작성 메뉴를 선택한다.
2. 시스템이 사용 가능한 결재 양식 목록을 표시한다.
3. 기안자가 결재 양식을 선택한다. 시스템이 해당 양식의 빈 문서 레이아웃 HTML과 입력 필드 스키마를 조회하여 웹 에디터 화면에 서식(표, 결재란 등)을 렌더링한다.
4. 시스템이 해당 양식에 연결된 직위·직책 기반 결재선 템플릿을 조회한다.
5. 시스템이 기안자의 소속 부서를 기준으로 결재자를 자동 매핑한다.
6. 기안자가 결재선의 단계, 역할, 결재자를 확인한다.
7. 기안자가 필요 시 결재자를 수정하거나 참조자, 합의자를 추가한다.
8. 기안자가 웹 에디터 내의 렌더링된 표와 폼 양식에 맞춰 제목과 실제 데이터(금액, 사유 등)를 입력한다.
9. 기안자가 첨부파일을 등록한다.
10. 시스템이 첨부파일이 이미지 또는 PDF면 OCR 처리 대상으로 등록한다.
11. 시스템이 결재자 누락, 동일 역할 중복, 권한 여부를 검증한다.
12. 기안자가 상신 버튼을 클릭한다.
13. 시스템이 상신 확인 모달을 표시한다.
14. 기안자가 상신 확인을 누르면, 시스템은 기안자가 입력한 실제 데이터와 렌더링된 최종 병합 HTML을 추출한다. 이때 시스템은 악성 스크립트 방지를 위해 HTML에 XSS 필터링을 거친 후 문서와 결재선을 DB에 저장한다.
15. 시스템이 첫 번째 결재자에게 알림을 생성한다.
16. 시스템이 기안자를 내 기안함으로 이동시킨다.

대안 흐름

- A1. 임시저장 (12단계에서 분기)
 - 12a. 기안자가 '임시저장' 버튼을 클릭한다.

- 12b. 시스템은 결재선 완성 여부와 무관하게 문서를 **DRAFT** 상태로 저장한다.
- 12c. 시스템은 "임시저장 되었습니다" 메시지를 표시하고 **작성 화면**을 유지한다.
- **A2. 결재선 수정 (6단계에서 분기)**
 - 6a. 기안자가 자동 매핑된 결재선을 확인 후 **수정 버튼**을 클릭한다.
 - 6b. 시스템은 **조직도 및 결재선 수정 UI**를 표시한다.
 - 6c. 기안자가 **결재자**를 변경하고 저장한다.
 - 6d. 시스템은 수정된 결재선을 적용하며 기본 흐름 7단계로 복귀한다.
- **A3. 첨부파일 없음 (9단계에서 분기)**
 - 9a. 기안자가 첨부파일을 등록하지 않고 다음 단계를 진행한다.
 - 9b. 시스템은 **OCR 처리 대상 등록**을 생략하고 기본 흐름 11단계로 이동한다.
- **A4. 참조자 추가 (7단계에서 분기)**
 - 7a. 기안자가 '참조자 추가' 버튼을 클릭한다.
 - 7b. 시스템은 **조직도 UI**를 추가 표시한다.
 - 7c. 기안자가 결재 없이 진행 상황만 확인할 사용자를 선택하고 저장한다.
 - 7d. 시스템은 선택된 사용자를 참조자로 반영하고 기본 흐름 8단계로 복귀한다.
- **A5. 합의자 추가 (7단계에서 분기)**
 - 7e. 기안자가 '합의자 추가' 버튼을 클릭한다.
 - 7f. 시스템은 **조직도 UI**를 추가 표시한다.
 - 7g. 기안자가 타 부서 협조 등이 필요한 사용자를 선택하고 저장한다.
 - 7h. 시스템은 선택된 사용자를 합의자로 반영하고 기본 흐름 8단계로 복귀한다.

예외 흐름

- **E1. 결재자 미지정 (11단계에서 발생)**
 - 11a. 시스템은 "결재자는 최소 1명 이상 지정해야 합니다." 메시지를 표시한다.
 - 11b. **상신 버튼**을 비활성화(Disabled) 처리하고 기안자가 결재선을 수정하도록 유도한다.
- **E2. 동일 결재자 중복 (11단계에서 발생)**
 - 11c. 시스템은 "동일 사용자를 동일 역할에 중복 지정할 수 없습니다." 메시지를 표시한다.
 - 11d. 기안자가 중복을 해제하도록 결재선 수정 UI를 활성화한다.
- **E3. 템플릿 매핑 실패 (5단계에서 발생)**
 - 5a. 시스템은 "해당 결재 역할에 매핑된 사용자가 없습니다." 메시지를 표시한다.
 - 5b. 시스템은 기안자에게 직접 결재자를 지정하도록 결재선 수정 UI를 활성화한다.
- **E4. 권한 없는 결재자 지정 (11단계에서 발생)**
 - 11e. 시스템은 "권한 없는 결재자가 포함되었습니다" 메시지를 표시한다.
 - 11f. 기안자가 올바른 권한의 사용자로 수정하도록 결재선 수정 UI를 활성화한다.

• **E5. 악성 콘텐츠 포함 (14단계에서 발생)**

- 14a. 시스템이 웹 에디터로부터 추출된 HTML 데이터를 검증(XSS 필터링)하는 과정에서 허용되지 않는 악성 스크립트 코드나 변조용 태그(<script>, javascript:, onerror 등)를 탐지한다.
- 14b. 시스템은 보안 정책에 따라 즉시 트랜잭션을 중단(Abort)하고 상신 프로세스를 전면 취소한다.
- 14c. 시스템은 화면에 "허용되지 않는 악성 스크립트나 태그가 포함되어 있습니다." 예외 메시지(400 Bad Request / INVALID_SECURITY_CONTENT)를 표시하고 기안자에게 수정 작성을 요구한다.

4.2 UC-DOC-02 상신 후 즉시 수정 및 회수

항목	내용
유스케이스명	상신 후 즉시 수정 및 회수
ID	UC-DOC-02
주요 액터	기안자
보조 액터	감사 로그 시스템
우선순위	Must

사전 조건

- 사용자는 로그인 상태여야 한다.
- 사용자는 해당 문서의 기안자여야 한다.
- 문서는 최종 승인 상태가 아니어야 한다.

사후 조건

- 즉시 수정 시 문서 버전이 증가한다.
- 수정 이력이 document_versions 와 audit_logs 에 기록된다.
- 회수 시 문서 상태가 WITHDRAWN 으로 변경된다.
- 회수 이력이 approval_actions 와 audit_logs 에 기록된다.

불변식

- 다음 결재자가 이미 문서를 열람한 경우 즉시 수정할 수 없다.
- 최종 승인된 문서는 회수할 수 없다.
- 수정 및 회수 이력은 삭제할 수 없다.

기본 흐름: 즉시 수정

1. 기안자가 내 기안함에서 상신한 문서를 선택한다.

2. 시스템이 다음 결재자의 최초 열람 여부를 확인한다.
3. 다음 결재자가 아직 열람하지 않은 경우, 시스템은 즉시 수정 버튼을 표시한다.
4. 기안자가 즉시 수정 버튼을 클릭한다.
5. 시스템이 문서 편집 화면을 표시한다.
6. 기안자가 본문 또는 첨부파일을 수정한다.
7. 시스템이 수정 내용을 검증한다.
8. 기안자가 저장 버튼을 누른다.
9. 시스템이 문서 버전을 증가시키고 수정 이력을 저장한다.
10. 문서는 기존 결재 진행 상태(IN_PROGRESS)를 유지한 채 목록으로 복귀한다.

기본 흐름: 회수

1. 기안자가 내 기안함에서 상신한 문서를 선택한다.
2. 기안자가 회수 버튼을 클릭한다.
3. 시스템이 회수 사유 입력 모달을 표시한다.
4. 기안자가 회수 사유를 입력한다.
5. 시스템은 회수 가능 상태(승인 전)인지 검증한다.
6. 시스템은 문서 상태를 WITHDRAWN 으로 변경한다.
7. 시스템은 해당 문서를 임시저장함으로 이동시킨다.
8. 시스템은 회수 이력을 저장하고 목록으로 복귀한다.

대안 흐름

- **A1. 즉시 수정 불가 시 회수 전환 (즉시 수정 흐름 3단계에서 분기)**
 - 3a. 시스템은 다음 결재자가 이미 열람했음을 확인하고 '즉시 수정' 버튼을 숨긴다.
 - 3b. 시스템은 대신 '회수' 버튼만 활성화하여 표시한다.
 - 3c. 기안자가 '회수' 버튼을 클릭하면 회수 기본 흐름 3단계로 이동한다.
- **A2. 회수 후 재상신 연계 (회수 흐름 8단계에서 분기)**
 - 8a. 기안자가 임시저장함으로 이동된 회수 문서를 다시 선택한다.
 - 8b. 시스템은 이전 입력 내용이 그대로 유지된 문서 작성 화면을 표시한다. (이후 UC-D0C-01 흐름으로 연계)

예외 흐름

- **E1. 다음 결재자 이미 열람 (즉시 수정 흐름 4단계에서 발생)**
 - 4a. 화면 갱신 지연 등으로 인해 버튼을 클릭했으나 시스템 검증 시 이미 결재자가 열람한 상태이다.
 - 4b. 시스템은 "다음 결재자가 이미 열람하여 즉시 수정할 수 없습니다." 메시지를 표시한다.
 - 4c. 시스템은 수정 요청을 거부하고 버튼을 숨긴다.
- **E2. 회수 사유 미입력 (회수 흐름 5단계에서 발생)**

- 5a. 기안자가 회수 사유를 입력하지 않고 모달의 '확인' 버튼을 누른다.
- 5b. 시스템은 "회수 사유를 입력해야 합니다." 메시지를 표시한다.
- 5c. 시스템은 회수 진행을 중단하고 사유 입력 모달 창을 그대로 유지한다.
- E3. 최종 승인 문서 회수 시도 (회수 흐름 5단계에서 발생)
 - 5d. 시스템 상태 검증 시 문서가 이미 최종 승인 완료 처리된 상태이다.
 - 5e. 시스템은 "최종 승인된 문서는 회수할 수 없습니다." 메시지를 표시한다.
 - 5f. 시스템은 회수 모달을 닫고 상세 화면으로 복귀시킨다.
- E4. 기안자가 아닌 사용자 접근 (양쪽 기본 흐름 1단계에서 발생)
 - 1a. 문서의 최초 기안자가 아닌 사용자(결재자, 참조자 등)가 해당 문서에 접근한다.
 - 1b. 시스템은 '즉시 수정' 및 '회수' 버튼 자체를 화면에 렌더링하지 않는다.
 - 1c. 강제 API 요청 시 "문서 작성자만 수정/회수할 수 있습니다." 메시지를 반환한다.

4.3 UC-APP-01 결재 승인

항목	내용
유스케이스명	결재 승인
ID	UC-APP-01
주요 액터	결재자
보조 액터	인증 시스템, 알림 시스템, 감사 로그 시스템
우선순위	Must

사전 조건

- 사용자는 로그인 상태여야 한다.
- 사용자는 해당 문서의 현재 결재 순서에 해당해야 한다.
- 문서는 IN_PROGRESS 상태여야 한다.

사후 조건

- 승인 이력이 approval_actions 에 저장된다.
- 결재선의 해당 단계 상태가 APPROVED 로 변경된다.
- 다음 결재자가 있으면 알림이 생성된다.
- 마지막 결재자라면 문서 상태가 APPROVED 로 변경된다.
- 고위험 문서 승인 시 인증 검증 결과가 기록된다.

불변식

- 현재 결재 순서가 아닌 사용자는 승인할 수 없다.
- 동일 결재 단계는 중복 승인될 수 없다.
- 고위험 문서는 본문 핵심 확인 조건을 만족해야 한다.
- 인증이 필요한 상황에서는 인증 검증을 통과해야 한다.
- 미처리 합의자가 있는 경우 최종 승인 상태로 전환할 수 없다.

기본 흐름

1. 결재자가 결재함에서 대기 문서를 선택한다.
2. 시스템은 결재 문서 상세 내용을 표시한다. 이때 시스템은 해당 결재자의 최초 열람 시점 (`first_viewed_at`)을 현재 시간으로 기록한다.
3. 시스템은 사용자가 현재 결재자인지 확인한다.
4. 현재 결재자라면 승인 버튼을 표시한다.
5. 결재자가 문서 내용을 확인한다.
6. 결재자가 승인 버튼을 클릭한다.
7. 시스템은 문서 위험도를 확인한다.
8. 일반 문서라면 즉시 승인 조건이 충족된 것으로 간주하고 처리를 진행한다.
9. 조건을 만족하면 시스템은 승인 이력을 저장한다.
10. 다음 결재자가 있으면 다음 단계로 이동하고 알림을 생성한다.
11. 마지막 결재자라면 문서 상태를 `APPROVED` 로 변경한다.

대안 흐름

- **A1. 고위험 문서 승인 (7단계에서 분기)**
 - 7a. 시스템은 문서 위험도가 고위험임을 확인한다.
 - 7b. 시스템은 스크롤 끝까지 이동(본문 확인 여부) 및 2차 인증(2FA) 상태를 추가로 검증한다.
 - 7c. 검증을 통과하면 기본 흐름 9단계로 복귀한다.
- **A2. 전결 처리 (6단계에서 분기)**
 - 6a. 결재자가 '전결' 버튼을 클릭한다.
 - 6b. 시스템은 해당 결재자가 전결 권한이 있는지 확인한다.
 - 6c. 차순위 결재자를 생략한다. 단, 미처리된 필수 합의자가 있는 경우 최종 승인 처리를 유예하고 모든 합의가 완료될 때까지 대기 상태를 유지한다.
- **A3. 병렬 결재 (10단계에서 분기)**
 - 10a. 시스템은 현재 단계가 병렬 결재 단계임을 확인한다.
 - 10b. 1명의 승인 이력을 저장하되, 다음 결재 단계로 바로 넘어가지 않고 대기한다.
 - 10c. 병렬 결재자 전원이 승인한 시점에만 다음 단계로 이동(또는 최종 승인 처리)한다.

• **A4. 일괄 결재 (1단계 이전(결재함 목록)에서 분기)**

- 1a. 결재자가 결재 대기함 목록에서 여러 개의 일반 문서를 체크박스로 동시 선택한다.
- 1b. 결재자가 화면 상단의 '일괄 승인' 버튼을 클릭한다.
- 1c. 시스템은 선택된 문서들에 '고위험' 문서가 없는지, 현재 본인이 결재자인지 일괄 검증한다.
- 1d. 시스템은 문서를 순차적으로 자동 승인 처리하고 "선택한 항목이 모두 승인되었습니다" 메시지와 함께 목록을 갱신한다.

예외 흐름

• **E1. 현재 결재자가 아님 (3단계에서 발생)**

- 3a. 시스템 확인 결과 접속자가 현재 결재 순서의 대상자가 아니다.
- 3b. 시스템은 승인 버튼을 미표시한다.

• **E2. 중복 승인 (6단계에서 발생)**

- 6a. 중복 클릭 또는 네트워크 지연으로 인해 이미 승인 처리된 단계에 다시 승인이 요청된다.
- 6b. 시스템은 "이미 처리된 결재 단계입니다." 메시지를 표시한다.

• **E3. 고위험 문서 본문 미확인 (A1의 7b단계에서 발생)**

- 7b-1. 고위험 문서임에도 결재자가 스크롤을 끝까지 내리지 않았다.
- 7b-2. 시스템은 승인 버튼을 비활성화하고 승인을 막는다.

• **E4. 재인증 필요 (A1의 7b단계 또는 일괄 승인 시 발생)**

- 7b-3. 보안 세션이 만료되었거나 고위험 문서 결재를 위한 2차 인증이 확인되지 않았다.
- 7b-4. 시스템은 결재를 보류하고 재인증(2FA 또는 재로그인) 화면으로 강제 이동시킨다.

• **E5. 미처리 합의자 존재 (기본 11단계 또는 A2 전결 처리 시 발생)**

- 11a. 결재자가 승인(또는 전결)하여 최종 승인 상태로 넘어가려 하나, 필수 '합의자'가 아직 합의 처리를 하지 않았다.
- 11b. 시스템은 최종 승인 상태 전환을 제한하고 진행을 대기시킨다.

• **E6. 일괄 결재 중 고위험 문서 포함 (A4의 1c단계에서 발생)**

- 1c-1. 일괄 선택된 문서 목록 중에 고위험 문서가 포함되어 있다.
- 1c-2. 시스템은 "고위험 문서는 일괄 결재할 수 없습니다. 개별 확인 후 승인해주세요." 메시지를 표시하고 일괄 승인 진행을 전면 중단한다.

4.4 UC-APP-02 결재 반려

항목	내용
유스케이스명	결재 반려
ID	UC-APP-02

주요 액터	결재자
보조 액터	알림 시스템, 감사 로그 시스템
우선순위	Must

사전 조건

- 사용자는 로그인 상태여야 한다.
- 사용자는 현재 결재 순서의 결재자여야 한다.
- 문서는 최종 승인 또는 회수 상태가 아니어야 한다.

사후 조건

- 반려 이력이 approval_actions 에 저장된다.
- 반려 사유가 저장된다.
- 반려 대상에 따라 문서 상태가 변경된다.
- 대상자에게 알림이 생성된다.

불변식

- 반려 사유는 반드시 입력되어야 한다.
- 현재 결재자가 아닌 사용자는 반려할 수 없다.
- 반려 이력은 삭제할 수 없다.

기본 흐름

1. 결재자가 결재 상세 화면에 진입한다.
2. 시스템은 사용자가 현재 결재자인지 확인한다.
3. 시스템은 반려 버튼을 표시한다.
4. 결재자가 반려 버튼을 클릭한다.
5. 시스템은 반려 사유 입력 모달을 표시한다.
6. 결재자가 반려 사유를 입력한다.
7. 결재자가 반려 대상을 선택한다.
8. 시스템은 반려 사유와 대상을 검증한다.
9. 시스템은 승인 내역에 반려 이력을 저장한다.
10. 시스템은 대상자에게 알림을 생성한다.
11. 시스템은 결재함을 갱신한다.

대안 흐름

- A1. 반려 사유 템플릿 사용 (6단계에서 분기)

- 6a. 결재자가 반려 사유 입력 모달에서 '**자주 쓰는 사유(템플릿)**' 드롭다운을 클릭한다.
- 6b. 결재자가 템플릿 중 하나를 선택한다.
- 6c. 시스템은 선택된 내용을 **텍스트 영역에 자동 입력**한다.
- 6d. 결재자가 필요 시 텍스트를 추가로 수정하고 **기본 흐름 7단계**로 복귀한다.
- **A2. 기안자에게 반려 (7단계에서 분기)**
 - 7a. 결재자가 반려 대상으로 '**기안자**'를 선택하고 **확인 버튼**을 클릭한다.
 - 7b. 시스템은 문서 상태를 **REJECTED** 로 변경하고 해당 문서를 **기안자의 반려함**으로 이동시킨다. (이후 **기본 흐름 8단계**로 합류)
- **A3. 이전 단계로 반려 (7단계에서 분기)**
 - 7c. 결재자가 반려 대상으로 '**이전 단계 결재자**'를 선택하고 **확인 버튼**을 클릭한다.
 - 7d. 시스템은 문서 상태를 **IN_PROGRESS** 로 유지한 채, 해당 문서를 **이전 결재자의 대기함**으로 다시 이동시킨다. (이후 **기본 흐름 8단계**로 합류)

예외 흐름

- **E1. 반려 사유 미입력 (8단계에서 발생)**
 - 8a. 결재자가 반려 사유를 비워둔 채 확인을 누른다.
 - 8b. 시스템은 "**반려 사유를 입력해야 합니다.**" 메시지를 표시한다.
 - 8c. 시스템은 반려 처리를 중단하고 사유 입력 모달을 그대로 유지한다.
- **E2. 반려 사유 길이 부족 (8단계에서 발생)**
 - 8d. 결재자가 입력한 반려 사유가 10자 미만이다.
 - 8e. 시스템은 "**반려 사유는 10자 이상 입력해야 합니다.**" 메시지를 표시한다.
 - 8f. 시스템은 반려 처리를 중단하고 사유 입력 모달을 그대로 유지한다.
- **E3. 현재 결재자가 아님 (2단계에서 발생)**
 - 2a. 시스템 확인 결과 접속자가 해당 문서의 현재 결재 대상자가 아니다.
 - 2b. 시스템은 화면에 **반려 버튼을 미표시**한다.
 - 2c. 비정상적인 강제 API 요청 시 **요청을 거부**한다.
- **E4. 완료 문서 반려 시도 (기본 흐름 진입 전/1단계에서 발생)**
 - 1a. 문서가 이미 **최종 승인** 완료 처리되어 더 이상 진행 상태가 아니다.
 - 1b. 시스템은 반려 진행을 막고, 강제 요청 시 **요청을 거부**한다.

4.5 UC-ADMIN-01 부서별 결재 양식 및 리스크 기준 관리

항목	내용
유스케이스명	부서별 결재 양식 및 리스크 기준 관리

ID	UC-ADMIN-01
주요 액터	부서 관리자
보조 액터	권한 시스템, 감사 로그 시스템
우선순위	Must

사전 조건

- 사용자는 **로그인 상태**여야 한다.
- 사용자는 해당 부서의 **부서 관리자 권한**을 가지고 있어야 한다.
- 관리 대상 양식은 해당 부서 소관이어야 한다.

사후 조건

- 부서별 결재 양식이 생성 또는 수정된다.
- 양식별 고위험 기준이 저장된다.
- 직위·직책 기반 결재선 템플릿이 저장된다.
- 변경 이력은 `audit_logs`에 기록된다.

불변식

- 관리자는 로그인 정책, 2FA 정책, IP 접근 제한 등 시스템 코어 설정만 담당한다.
- 부서 관리자는 자신의 부서에 속한 **결재 양식, 리스크 기준, 결재선 템플릿**만 관리할 수 있다.
- 다른 부서의 **결재 양식**과 **리스크 기준**은 수정할 수 없다.
- **리스크 기준**과 **결재선 템플릿** 변경은 **감사 로그**에 기록되어야 한다.

기본 흐름

1. 부서 관리자가 **부서 관리자 메뉴(결재 양식 관리 화면)**에 진입한다.
2. 시스템은 해당 부서에서 **관리 가능한 결재 양식 목록**을 표시한다.
3. 부서 관리자가 **양식 생성 또는 수정**을 선택한다.
4. 부서 관리자가 양식명, 설명, 기본 위험도, 사용 여부를 입력한다. **부서 관리자가 양식 빌더(웹 에디터)를 통해 회사 고유의 서식 레이아웃(표 크기, 폰트, 결재란 위계 등)을 디자인하여 HTML 템플릿을 작성한다. 디자인된 템플릿 내에 사용자가 기입할 입력 필드 속성을 매핑하여 스키마를 정의한다.**
5. 부서 관리자가 **고위험 문서 판정 기준**을 설정한다.
6. 부서 관리자가 **전결 기준 또는 금액 기준**을 입력한다.
7. 부서 관리자가 **직위·직책 기반 결재선 템플릿**을 설정한다.
8. 시스템은 **필수 결재 단계 누락 여부**와 **중복 규칙 여부**를 검증한다.
9. 부서 관리자가 **저장 버튼**을 클릭한다.
10. 시스템은 **양식, 리스크 기준, 결재선 템플릿**을 저장한다.

l1. 시스템은 변경 이력을 감사 로그에 기록하고 목록 화면으로 복귀한다.

대안 흐름

- **A1. 기존 양식 복사 (3단계에서 분기)**
 - 3a. 부서 관리자가 기존 양식 목록에서 '복사'를 선택한다.
 - 3b. 시스템은 기존 양식의 정보가 채워진 상태로 새 양식 생성 화면을 표시한다.
 - 3c. 이후 부서 관리자가 정보를 일부 수정하며 기본 흐름 4단계로 연계된다.
- **A2. 리스크 기준 비활성화 (5단계에서 분기)**
 - 5a. 부서 관리자가 해당 양식에 대해 고위험 기준을 적용하지 않음으로 설정한다.
 - 5b. 시스템은 리스크 기준 입력 필드를 비활성화하고 기본 흐름 6단계로 이동한다.
- **A3. 템플릿 단계 추가 (7단계에서 분기)**
 - 7a. 부서 관리자가 결재선 템플릿 설정 중 '단계 추가' 버튼을 클릭한다.
 - 7b. 시스템은 부서장, 재무 담당자 등 추가 결재 단계를 등록할 수 있는 UI를 제공한다.
 - 7c. 부서 관리자가 요구 직위/직책을 설정하고 기본 흐름 8단계로 복귀한다.
- **A4. 전결 기준 설정 (6단계에서 분기)**
 - 6a. 부서 관리자가 일정 금액 이하 또는 특정 조건을 전결 기준으로 입력한다.
 - 6b. 시스템은 해당 조건 만족 시 중간 결재 단계를 생략하도록 정책을 템플릿에 반영하고 기본 흐름 7단계로 복귀한다.

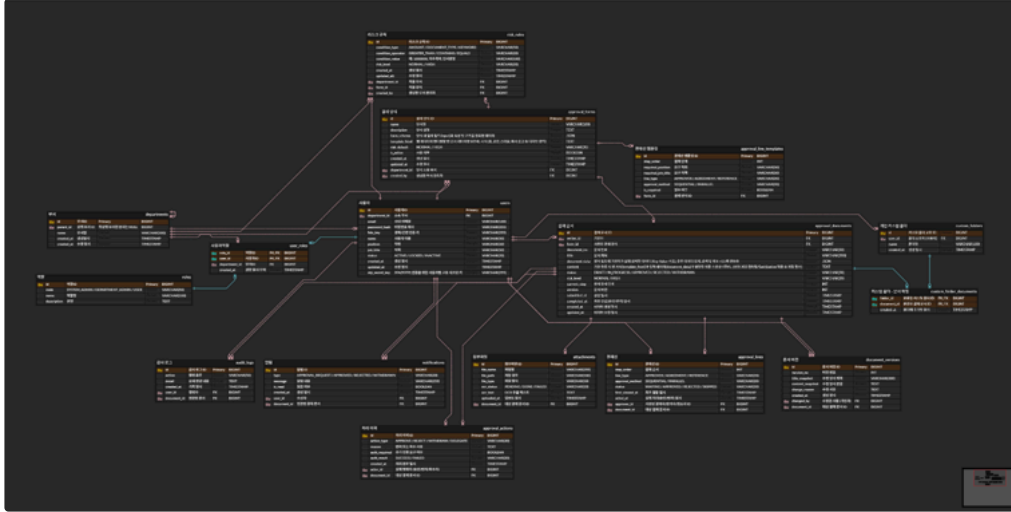
예외 흐름

- **E1. 부서 관리자 권한 없음 (1단계에서 발생)**
 - 1a. 시스템 권한 검증 결과 접속자가 부서 관리자 권한이 없다.
 - 1b. 시스템은 접근 요청을 거부하고 권한 없음 안내 페이지로 리다이렉트한다.
- **E2. 다른 부서 양식 수정 시도 (3단계에서 발생)**
 - 3a. URL 조작 등을 통해 다른 부서 소관의 양식 수정을 시도한다.
 - 3b. 시스템은 "해당 부서 양식을 수정할 권한이 없습니다." 메시지를 표시한다.
 - 3c. 시스템은 수정을 즉시 차단하고 목록 화면으로 복귀시킨다.
- **E3. 고위험 기준 중복 (8단계 검증 시 발생)**
 - 8a. 시스템 검증 결과 새로 등록하려는 리스크 기준이 기존 조건과 중복된다.
 - 8b. 시스템은 "이미 동일한 리스크 기준이 존재합니다." 메시지를 표시한다.
 - 8c. 시스템은 저장을 중단하고 해당 입력 필드에 포커스를 맞춘다.
- **E4. 필수 결재 단계 누락 (8단계 검증 시 발생)**
 - 8d. 결재선 템플릿에 회사의 필수 통제 단계(예 : 부서장 승인)가 누락되어 있다.
 - 8e. 시스템은 "필수 결재 단계가 누락되었습니다." 메시지를 표시한다.
 - 8f. 시스템은 저장을 중단하고 결재선 설정 화면을 유지한다.

5. ERD 설계 및 데이터 사전

5.1 ERD 설계 방향

<https://www.erdcloud.com/d/zNEv4njwuh5JKzXMX>



전자결재 시스템의 핵심 데이터는 사용자, 조직, 권한, 결재 양식, 리스크 규칙, 결재선 템플릿, 결재 문서, 결재 선, 결재 처리 이력, 문서 버전, 첨부파일, 알림, 감사 로그로 구성된다.

1	[departments]	1 - N	[departments]	(상위 부서 자기 참조)
2	[departments]	1 - N	[users]	(소속 부서)
3	[departments]	1 - N	[approval_forms]	(부서별 소관 양식)
4	[departments]	1 - N	[risk_rules]	(부서별 리스크 기준)
5				
6	[users]	N - M	[roles] via [user_roles]	(권한 부여, 부서 관리자 제어)
7	[users]	1 - N	[approval_documents]	(기안자)
8	[users]	1 - N	[approval_lines]	(결재자/합의자/참조자)
9	[users]	1 - N	[approval_actions]	(처리자)
10	[users]	1 - N	[notifications]	(수신자)
11	[users]	1 - N	[audit_logs]	(행위자)
12	[users]	1 - N	[custom_folders]	(폴더 소유자)
13				
14	[approval_forms]	1 - N	[approval_line_templates]	(양식별 결재선 템플릿)
15	[approval_forms]	1 - N	[risk_rules]	(양식별 리스크 기준)
16				
17	[approval_documents]	1 - N	[approval_lines]	(문서에 포함된 결재선)
18	[approval_documents]	1 - N	[approval_actions]	(문서의 결재 처리 이력)
19	[approval_documents]	1 - N	[document_versions]	(상신 후 즉시 수정 이력)
20	[approval_documents]	1 - N	[attachments]	(문서 첨부파일)
21	[approval_documents]	1 - N	[custom_folder_documents]	(폴더에 분류된 문서)
22				
23	[custom_folders]	1 - N	[custom_folder_documents]	(폴더 내 문서 매핑)

5.2 제3정규화 검증

정규화 단계	만족 여부	검증 내용
--------	-------	-------

1NF	만족	모든 컬럼은 원자값만 가진다. 결재자 목록이나 첨부파일 목록을 한 컬럼에 콤마(,) 등으로 저장하지 않고 <code>approval_lines</code> , <code>attachments</code> 테이블로 분리했다.
2NF	만족	복합키에 일부만 종속되는 컬럼을 두지 않았다. 예를 들어 <code>user_roles</code> 테이블은 '사용자-역할' 매핑 관계만 저장할 뿐, 사용자 이름이나 역할의 구체적 설명을 중복 저장하지 않았다.
3NF	만족	이행 종속을 제거했다. 결재 문서(<code>approval_documents</code>)에 기안자의 이름이나 부서명을 직접 저장하지 않고 <code>users</code> 를 FK로 참조한다. 부서 관리자의 관리 범위 또한 <code>user_roles</code> 의 <code>department_id</code> 를 통해 참조 무결성을 유지한다.

5.3 데이터 사전

1. 조직 및 권한 테이블

[departments] 부서

컬럼명	타입	제약조건	설명
id	BIGINT	PK	부서 ID
parent_id	BIGINT	FK → departments, NULLABLE	상위 부서 ID (최상위 부서인 본사는 NULL)
name	VARCHAR(100)	NOT NULL	부서명
created_at	TIMESTAMP	NOT NULL	생성 일시
updated_at	TIMESTAMP	NOT NULL	수정 일시

[users] 사용자

컬럼명	타입	제약조건	설명
id	BIGINT	PK	사용자 ID
email	VARCHAR(100)	UNIQUE, NOT NULL	사내 이메일
password_hash	VARCHAR(255)	NOT NULL	비밀번호 해시
fido_key	VARCHAR(255)	NULLABLE	생체/간편 인증 키 (초기 등록 전 NULL)

name	VARCHAR(50)	NOT NULL	사용자 이름
department_id	BIGINT	FK → departments	소속 부서
position	VARCHAR(50)	NOT NULL	직위
job_title	VARCHAR(50)	NULLABLE	직책
status	VARCHAR(20)	NOT NULL	ACTIVE / LOCKED / INACTIVE
created_at	TIMESTAMP	NOT NULL	생성 일시
updated_at	TIMESTAMP	NOT NULL	수정 일시
otp_secret_key	VARCHAR(255)	NULLABLE	2FA(TOTP) 인증을 위한 사용자별 고유 시크릿 키(초기 등록 전 NULL)

[roles] 역할

컬럼명	타입	제약조건	설명
id	BIGINT	PK	역할 ID
code	VARCHAR(50)	UNIQUE, NOT NULL	SYSTEM_ADMIN / DEPARTMENT_ADMIN / USER
name	VARCHAR(100)	NOT NULL	역할명
description	TEXT	NULLABLE	설명

[user_roles] 사용자 역할 매핑

컬럼명	타입	제약조건	설명
user_id	BIGINT	PK, FK → users	사용자 ID
role_id	BIGINT	PK, FK → roles	역할 ID
department_id	BIGINT	FK → departments, NULLABLE	부서 관리자 권한 적용 부서 (전체 관리자는 NULL)
created_at	TIMESTAMP	NOT NULL	권한 부여 일시

2. 전자결재 양식 및 템플릿 테이블

[approval_forms] 결재 양식

컬럼명	타입	제약조건	설명
id	BIGINT	PK	결재 양식 ID
department_id	BIGINT	FK → departments	양식 소유 부서
name	VARCHAR(100)	NOT NULL	양식명
description	TEXT	NULLABLE	양식 설명
form_schema	JSON	NULLABLE	양식 내 입력 필드 (Input)의 속성 및 구조를 정의한 데이터
template_html	TEXT	NULLABLE	웹 에디터에 렌더링할 빈 문서 레이아웃 HTML 서식 (표, 폰트 스타일, 회사 로고 등 디자인 영역)
risk_default	VARCHAR(20)	NOT NULL	NORMAL / HIGH
is_active	BOOLEAN	DEFAULT true	사용 여부
created_by	BIGINT	FK → users	생성한 부서 관리자
created_at	TIMESTAMP	NOT NULL	생성 일시
updated_at	TIMESTAMP	NOT NULL	수정 일시

[risk_rules] 리스크 규칙

컬럼명	타입	제약조건	설명
id	BIGINT	PK	리스크 규칙 ID
department_id	BIGINT	FK → departments	적용 부서
form_id	BIGINT	FK → approval_forms	적용 양식
condition_type	VARCHAR(50)	NOT NULL	AMOUNT / DOCUMENT_TYPE / KEYWORD

condition_operator	VARCHAR(20)	NULLABLE	GREATER_THAN / CONTAINS / EQUALS
condition_value	VARCHAR(100)	NOT NULL	조건값
risk_level	VARCHAR(20)	NOT NULL	NORMAL / HIGH
created_by	BIGINT	FK → users	생성한 부서 관리자
created_at	TIMESTAMP	NOT NULL	생성 일시
updated_at	TIMESTAMP	NOT NULL	수정 일시

[approval_line_templates] 결재선 템플릿

컬럼명	타입	제약조건	설명
id	BIGINT	PK	결재선 템플릿 ID
form_id	BIGINT	FK → approval_forms	결재 양식 ID
step_order	INT	NOT NULL	결재 단계
required_position	VARCHAR(50)	NULLABLE	요구 직위
required_job_title	VARCHAR(50)	NULLABLE	요구 직책
line_type	VARCHAR(20)	NOT NULL	APPROVER / AGREEMENT / REFERENCE
approval_method	VARCHAR(20)	NOT NULL	SEQUENTIAL / PARALLEL
is_required	BOOLEAN	DEFAULT true	필수 여부

3. 결재 문서 및 진행 관련 테이블

[approval_documents] 결재 문서

컬럼명	타입	제약조건	설명
id	BIGINT	PK	결재 문서 ID
document_no	VARCHAR(50)	UNIQUE, NOT NULL	문서 번호

			(예 : APP-2026-001)
writer_id	BIGINT	FK → users	기안자
form_id	BIGINT	FK → approval_forms	사용된 결재 양식
title	VARCHAR(200)	NOT NULL	문서 제목
document_data	JSON	NOT NULL	양식 필드에 기안자가 실제 입력한 데이터 (Key-Value 구조). 추후 데이터 집계, 검색 및 외부 시스템 연동용
content	TEXT	NOT NULL	기안 완료 시 빈 서식 (template_html)과 입력 데이터 (document_data)가 병합된 최종 스냅샷 HTML. (보안: XSS 필터링/Sanitization 적용 후 저장 필수)
status	VARCHAR(30)	NOT NULL	DRAFT / IN_PROGRESS / APPROVED / REJECTED / WITHDRAWN
risk_level	VARCHAR(20)	NOT NULL	NORMAL / HIGH (리스크 판정 결과)
current_step	INT	DEFAULT 1	현재 결재 단계
version	INT	DEFAULT 1	문서 버전 (즉시 수정 시 증가)

submitted_at	TIMESTAMP	NULLABLE	상신 일시
completed_at	TIMESTAMP	NULLABLE	최종 완료(승인/반려) 일시
created_at	TIMESTAMP	NOT NULL	데이터 생성 일시
updated_at	TIMESTAMP	NOT NULL	데이터 수정 일시

[approval_lines] 결재선 (실제 결재 진행 정보)

컬럼명	타입	제약조건	설명
id	BIGINT	PK	결재선 ID
document_id	BIGINT	FK → approval_documents	대상 결재 문서 ID
approver_id	BIGINT	FK → users	지정된 결재자/합의자/참조자 ID
step_order	INT	NOT NULL	결재 순서
line_type	VARCHAR(20)	NOT NULL	APPROVER / AGREEMENT / REFERENCE
approval_method	VARCHAR(20)	NOT NULL	SEQUENTIAL / PARALLEL
status	VARCHAR(20)	NOT NULL	WAITING / APPROVED / REJECTED / SKIPPED
first_viewed_at	TIMESTAMP	NULLABLE	최초 열람 일시 (즉시 수정 차단 기준점)
acted_at	TIMESTAMP	NULLABLE	실제 처리(승인/반려) 일시

[approval_actions] 결재 처리 이력

컬럼명	타입	제약조건	설명
id	BIGINT	PK	처리 이력 ID

document_id	BIGINT	FK → approval_documents	대상 결재 문서 ID
actor_id	BIGINT	FK → users	실제 행위자 (승인/반려/회수자)
action_type	VARCHAR(30)	NOT NULL	APPROVE(일반 승인) / REJECT(반려) / WITHDRAW(회수) / DELEGATE(전결)
reason	TEXT	NULLABLE	반려 또는 회수 사유 (필수 입력분)
auth_required	BOOLEAN	DEFAULT false	2FA 등 추가 인증 요구 여부 (고위험 문서용)
auth_result	VARCHAR(20)	NULLABLE	SUCCESS / FAILED
created_at	TIMESTAMP	NOT NULL	처리 완료 일시

[document_versions] 문서 버전 (즉시 수정 이력)

컬럼명	타입	제약조건	설명
id	BIGINT	PK	문서 버전 ID
document_id	BIGINT	FK → approval_documents	대상 결재 문서 ID
version_no	INT	NOT NULL	버전 번호
title_snapshot	VARCHAR(200)	NOT NULL	수정 당시 제목
content_snapshot	TEXT	NOT NULL	수정 당시 본문
changed_by	BIGINT	FK → users	수정한 사람 (기안자)
change_reason	TEXT	NULLABLE	수정 사유(필요시)
created_at	TIMESTAMP	NOT NULL	버전 생성 일시

[attachments] 첨부파일

컬럼명	타입	제약조건	설명
-----	----	------	----

id	BIGINT	PK	첨부파일 ID
document_id	BIGINT	FK → approval_documents	대상 결재 문서 ID
file_name	VARCHAR(255)	NOT NULL	파일명
file_path	VARCHAR(500)	NOT NULL	저장 경로
file_type	VARCHAR(50)	NOT NULL	파일 형식
ocr_status	VARCHAR(20)	NOT NULL	PENDING / DONE / FAILED (비동기 OCR 상태)
ocr_text	TEXT	NULLABLE	OCR 추출 텍스트
uploaded_at	TIMESTAMP	NOT NULL	업로드 일시

4. 시스템 통제 및 로그 관련 테이블

[notifications] 알림

컬럼명	타입	제약조건	설명
id	BIGINT	PK	알림 ID
user_id	BIGINT	FK → users	수신자
document_id	BIGINT	FK → approval_documents	연관된 결재 문서
type	VARCHAR(30)	NOT NULL	APPROVAL_REQUEST / APPROVED / REJECTED / WITHDRAWN
message	VARCHAR(255)	NOT NULL	알림 표시 메시지
is_read	BOOLEAN	DEFAULT false	사용자의 알림 확인 여부
created_at	TIMESTAMP	NOT NULL	알림 생성 일시

[audit_logs] 감사 로그

컬럼명	타입	제약조건	설명
id	BIGINT	PK	감사 로그 ID
user_id	BIGINT	FK → users	행위자 (주로 관리자 설정 변경 이력 추적용)
document_id	BIGINT	FK → approval_documents, NULLABLE	연관된 문서 (결재 외 시스템 설정 변경 시 NULL)
action	VARCHAR(50)	NOT NULL	행위 종류 (예 : UPDATE_RISK_RULE, WITHDRAW_DOC)
detail	TEXT	NULLABLE	상세 변경 내용 (JSON 형태 등)
created_at	TIMESTAMP	NOT NULL	기록 일시

5. 개인화 및 문서 분류 테이블

[custom_folders] 개인 커스텀 폴더

컬럼명	타입	제약조건	설명
id	BIGINT	PK	커스텀 폴더 고유 ID
user_id	BIGINT	FK → users	폴더 소유자 (사용자)
name	VARCHAR(100)	NOT NULL	폴더명
created_at	TIMESTAMP	NOT NULL	생성 일시

[custom_folder_documents] 커스텀 폴더 - 문서 매핑

컬럼명	타입	제약조건	설명
folder_id	BIGINT	PK, FK → custom_folders	분류할 커스텀 폴더 ID
document_id	BIGINT	PK, FK → approval_documents	분류된 결재 문서 ID

created_at	TIMESTAMP	NOT NULL	폴더에 추가된 일시
------------	-----------	----------	------------

6. 아키텍처 설계

6.1 아키텍처 선택

본 프로젝트는 독립적 어댑터를 갖춘 **확장된 계층형 아키텍처(Enhanced Layered Architecture)**를 채택한다. 전자결재 도메인의 특성상 '**사용자-조직-권한-문서 상태**'가 하나의 단일 트랜잭션 내에서 강력한 데이터 정합성(ACID)을 유지해야 하므로, 초기 단계에서 **분산 환경(MSA)**에 따른 트랜잭션 복잡성을 감수하기보다 **모놀리식 계층형 구조**를 메인 뼈대로 확정한다.

다만, 웹 에디터 도입에 따른 대용량 HTML 파싱, 외부 OCR 연동, 비동기 알림 발송 등 병목이 예상되는 기능들은 **비즈니스 로직**에서 철저히 **격리**하기 위해 맨 앞단의 보안 필터와 맨 뒷단의 **외부 어댑터(External Adapter) 계층**을 명시적으로 두어 관심사를 분리한다.

```

1  [Client: Web / Mobile Web]
2      ↓ REST API (HTTPS)
3  [Backend Application]
4      └─ Filter Layer
5          └─ XSS Sanitizer Filter
6
7      └─ Presentation Layer
8          └─ AuthController
9          └─ DocumentController
10         └─ ApprovalController
11         └─ DepartmentAdminController
12         └─ SearchController
13
14     └─ Business Layer
15         └─ AuthService
16         └─ DocumentService
17         └─ DocumentDataValidator
18         └─ ApprovalService
19         └─ ApprovalPolicy (Interface)
20             └─ GeneralApprovalPolicy
21             └─ HighRiskApprovalPolicy
22         └─ RiskRuleService
23         └─ ApprovalLineTemplateService
24         └─ SearchService
25         └─ NotificationService
26
27     └─ Data Access Layer
28         └─ UserRepository
29         └─ DocumentRepository
30         └─ ApprovalLineRepository
31         └─ RiskRuleRepository
32         └─ AttachmentRepository
33         └─ AuditLogRepository
34
35     └─ External Adapter
36         └─ Html Sanitizer Adapter
37         └─ OCR Adapter ── 연동 ──> [외부 OCR API]
38         └─ File Storage Adapter
39         └─ Notification Adapter ── 발행 ──> [Message Queue (Redis / RabbitMQ)]
40             ↓ (비동기 소비)

```


피드백 수정 부분

• Filter Layer (XSS Sanitizer Filter) 추가

- 단순히 텍스트를 받던 구조에서 웹 에디터의 HTML을 직접 받게 되면서 보안 위협(XSS)이 증가. 이를 막기 위해 Controller에 도달하기 전, 맨 앞단에 **Filter Layer** 를 두어 악성 스크립트 삽입 공격을 원천 차단

• Business Layer (DocumentDataValidator) 추가

- 기안자가 입력한 '실제 데이터(JSON)'와 '서식(HTML)'이 분리되어 들어오기 때문에, DocumentService가 비대해지는 것을 막고자 JSON 데이터의 구조와 필수 값을 검증하는 **Validator** 객체를 비즈니스 계층에 별도로 분리(SRP)"

• External Adapter (Html Sanitizer Adapter) 추가

- 비즈니스 로직 계층 내에서 호출되며, Jsoup 외부 라이브러리를 통해 허용된 안전한 UI 태그(표, 폰트 스타일 등)만 남기고 구조를 안전하게 정제(Sanitization)하여 DB 저장을 지원. 외부 기술 의존성을 완전히 격리하기 위해 어댑터 패턴을 적용

6.2 장단점 및 대가

장점	단점
구조가 단순하고 팀원이 이해하기 쉽다	기능이 커지면 Service 계층이 비대해질 수 있다
초기 서비스 구축 및 안정화 속도가 빠르다	결재, 문서, 권한 로직이 섞일 위험이 있다
조직도 변경, 전결 권한, 결재 상태 전환이 하나의 트랜잭션으로 묶여 결재 데이터의 절대적인 무결성(정합성)을 보장한다	OCR, 검색 같은 일부 기능만 독립 확장하기 어렵다
관심사 분리(SoC)의 기본 원칙을 충실히 지킬 수 있다	장기적으로 대규모 트래픽 발생 시 MSA보다 유연성이 낮다
서식(HTML)과 데이터(JSON)의 저장 구조를 철저히 분리하여, 실제 기업 환경의 복잡한 문서 시각화 요구를 충족함과 동시에 데이터 검색 및 집계용 용이성을 확보했다	프론트엔드와 백엔드 간 API 통신 시 HTML과 JSON을 이중으로 파싱하고 결합해야 하며, 보안을 위한 XSS 필터링 등 데이터 검증 파이프라인이 추가되어 구현 및 유지보수 복잡도가 증가했다

※ **단점 완화 방안**: 늘어난 데이터 검증 및 파싱 복잡도를 해결하기 위해, 단순 비즈니스 로직(DocumentService)과 JSON 데이터 검증 로직(DocumentDataValidator), 보안 검증 로직(XSS Filter)의 역할을 엄격히 분리(SRP)하여 유지보수성을 확보

6.3 SOLID 적용

원칙	적용 내용
SRP	<code>DocumentService</code> 는 결재 문서의 상태 전이 및 결재선 생성 로직만 담당한다. 웹 에디터 HTML 서식의 최종 정제 및 안전 태그 스냅샷 보존은 <code>HtmlSanitizerAdapter</code> 가 전담하며, 기안자가 입력한 원천 데이터(<code>document_data</code> JSON)의 스키마 검증은 <code>DocumentDataValidator</code> 가 전담하여 단일 책임을 엄격히 분리한다.
OCP	결재 승인 처리를 <code>ApprovalPolicy</code> 인터페이스로 추상화하고, 이를 구현한 <code>GeneralApprovalPolicy</code> (일반 문서 원클릭/일괄 승인)와 <code>HighRiskApprovalPolicy</code> (고위험 문서 스크롤 끝까지 내리기 및 2FA 강제 트리거)로 다형성을 구현했다. 향후 새로운 리스크 기반 자동 승인 규칙이 추가되더라도, 기존 <code>ApprovalService</code> 핵심 코드를 전혀 수정하지 않고 새로운 Policy 클래스 추가만으로 확장이 가능하다.
DIP	비즈니스 로직 계층의 모든 Service는 데이터 액세스 계층의 구체적인 구현체(MyBatis/JPA Entity 등)에 직접 의존하지 않고, 각각의 <code>Repository</code> 인터페이스에 의존한다. 이를 통해 인프라 기술의 변경에 유연하게 대처하며, 테스트 시 Mock Repository를 자유롭게 주입하여 비즈니스 로직만 고립시켜 검증할 수 있도록 설계했다.

7. ADR

[ADR-001] 아키텍처 패턴: 확장형 계층 아키텍처 선택

항목	내용
상태	승인
배경	전자결재 시스템은 결재 문서, 결재선, 승인, 반려, 권한, 인증, 검색 기능이 복잡하게 연결되어 있다. 초기 아키텍처 설계 시 MSA 도입을 검토했으나, 마이크로서비스 간 분산 트랜

	액션 관리 실패 시 '조직 구조 변경에 따른 권한 오동작'이나 '결재선 꼬임' 등 결재 시스템에서 치명적인 데이터 불일치 리스크가 발생할 수 있음을 인지함.
선택지	① 계층형 아키텍처 ② MSA ③ 독립적 외부 어댑터를 갖춘 확장형 계층 아키텍처
결정	독립적 외부 어댑터를 갖춘 확장형 계층 아키텍처
이유	전자결재 시스템의 최우선 가치인 '완벽한 데이터 무결성'을 단일 RDBMS의 ACID 트랜잭션 범위 내에서 안전하게 확보하기 위해 모놀리식 구조를 메인 뼈대로 설정한다. 다만, "단순 텍스트 박스를 벗어난 다이내믹 웹 서식 지원"이라는 UI/UX 요구사항을 만족시키기 위해 발생하는 무거운 HTML 파싱, XSS 방어, OCR 기술 의존성을 완전히 격리할 수 있도록 외부 어댑터 계층을 융합한다. 이는 정합성과 확장성을 모두 챙긴 도메인 특화 결정이다.
대가	모든 비즈니스 로직이 단일 애플리케이션 내에 집중되므로, 장기적으로 특정 대용량 파일 처리나 알림 트래픽 폭증 시 애플리케이션 전체에 영향을 줄 수 있는 비용이 발생한다.
완화 방안	병목이 확실시되는 파일 OCR 어댑터와 알림 어댑터의 아웃바운드 발행 단계 Message Queue(Redis/RabbitMQ)를 비동기로 연동하여 서버 부하를 최소화하고, 향후 부하가 큰 도메인만 즉시 마이크로서비스로 뜯어낼 수 있는 독립 구조를 유지한다.

[ADR-002] 결재 인증 방식: 위험도 기반 인증 이원화 (세션 유지 및 2FA)

항목	내용
상태	승인
배경	모든 결재 문서에 2FA나 FIDO 인증을 요구하면 보안성은 높지만, 하루에도 수십 건을 결재해야 하는 중간 관리자 및 임원진의 업무 흐름이 끊기고 극심한 피로도를 유발한다.
선택지	① 모든 문서 동일 승인 ② 고위험 문서마다 2FA 강제 ③ 위험도 기반 인증 이원화
결정	위험도 기반 인증 이원화 (일반 문서는 세션 기반 즉시 승인 / 고위험 문서는 2FA 트리거)
이유	일반 문서는 유효한 세션 기반으로 원클릭 승인 및 일괄 승인이 가능하도록 하여 편의성을 극대화한다. 반면, 재무 결재 등 고위험 문서에 한해 본문 전체 스크롤 확인 및 2차 인증(2FA)을 강제하여 편의성과 보안성이라는 트레이드오프를 합리적으로 조율한다.
대가	문서 상신 시 위험도를 동적으로 판단하는 로직과, 승인 시점에 세션 유효성 및 2FA 상태를 분기하여 검증하는 복잡한 보안 로직이 코드 레벨에 추가된다.
완화 방안	고위험 판정 기준은 <code>risk_rules</code> 테이블로 분리하여 데이터베이스화하고, 승인 정책은 다형성을 활용해 객체 지향적으로 분리하여 로직 결합도를 낮춘다.

[ADR-003] 관리자 역할 분리: 시스템 관리자와 부서 관리자 분리

항목	내용
상태	승인
배경	기존 설계처럼 단일 중앙 관리자가 모든 부서의 결재 양식, 복잡한 전결 규정, 고위험 여부를 전부 파악하고 세팅하는 것은 현실적으로 불가능하며 심각한 병목 현상을 초래한다.
선택지	① 중앙 관리자 일괄 관리 ② 세부 권한별 관리자 다수 분리 ③ 관리자와 부서 관리자 분리
결정	관리자와 부서 관리자 역할 분리
이유	관리자는 로그인 정책, 2FA, IP 제한 등 시스템 코어 설정만 통제한다. 부서 관리자(현업 팀장/부서장 등)에게는 소속 부서의 실무 양식, 리스크 기준, 직책 결재선 템플릿을 직접 세팅하고 운영할 수 있는 권한을 위임하여 관리 효율성과 유연성을 높인다.
대가	접속자가 일반 사용자인데서 동시에 특정 부서의 부서 관리자인지 식별하고 제어하는 복잡한 권한 검증 로직(<code>user_roles.department_id</code> 참조)이 추가되며, 부서별로 결재 양식 퀄리티의 편차가 발생할 수 있다.
완화 방안	부서 관리자에 의한 양식, 리스크 기준, 결재선 템플릿의 모든 변경 행위를 <code>audit_logs</code> 테이블에 빠짐없이 기록하여 중앙 차원에서의 사후 통제 및 추적이 가능하도록 방어적 설계를 적용한다.

[ADR-004] 동적 결재 양식 데이터 저장 전략: RDBMS JSON 컬럼 활용

항목	내용
상태	승인
배경	전자결재 시스템은 휴가신청서, 비용청구서, 장비구매요청서 등 부서와 업무에 따라 다양한 결재 양식을 지원해야 한다. 각 양식은 입력 필드가 다르기 때문에 모든 항목을 고정 컬럼으로 설계하면 양식이 추가될 때마다 테이블 구조를 계속 변경해야 한다. 또한 결재 문서 내 입력 데이터는 추후 검색, 집계, 감사 추적에 활용될 수 있어야 하며, 동시에 결재 완료 시점의 문서 화면도 그대로 재현할 수 있어야 한다.
선택지	① 정제되지 않은 HTML 문자열 전체를 단독 저장 ② MongoDB 같은 NoSQL 도입 ③ RDBMS의 JSON/JSONB 컬럼을 활용

결정	RDBMS의 JSON/JSONB 컬럼을 활용하여 양식 구조와 실제 입력 데이터를 저장하고, 화면 재현이 필요한 HTML은 XSS 필터링을 거친 안전한 스냅샷으로 별도 저장한다.
이유	초기 그룹웨어 시스템에서는 결재, 사용자, 조직, 권한, 감사 로그 등 트랜잭션 정합성이 중요한 데이터가 많기 때문에 단일 RDBMS를 유지하는 것이 운영과 유지보수에 유리하다. 동시에 결재 양식은 부서별로 필드 구조가 달라질 수 있으므로, RDBMS의 JSON/JSONB 컬럼을 사용해 NoSQL 수준의 유연성을 일부 확보한다. 정제되지 않은 HTML 원문만 저장하는 방식은 검색과 집계가 어렵고 XSS 같은 보안 위험이 있으므로 배제한다. 대신 사용자가 시각적으로 만족할 수 있는 프론트엔드 표현력(UI/UX)을 확보하면서도 백엔드의 데이터 활용성을 놓치지 않기 위해 , form_schema와 document_data를 JSON으로 분리 저장하여 데이터 활용성을 확보하고, 결재 당시 화면 재현이 필요한 경우에만 XSS 필터링을 거친 HTML 스냅샷을 content에 저장한다.
대가	화면을 구성하는 UI 서식과 실제 결재 데이터 JSON을 분리해서 관리해야 하므로 프론트엔드와 백엔드 간 API 페이로드 설계가 복잡해진다. 또한 template_html, document_data, content 사이의 정합성을 유지해야 하며, JSON 컬럼 내부 필드를 검색하거나 집계하려면 별도 인덱스 설계와 쿼리 최적화가 필요하다. HTML 스냅샷을 저장하는 경우 XSS 필터링 및 허용 태그 정책을 지속적으로 관리해야 하는 보안 비용도 발생한다.
완화 방안	approval_forms.form_schema 에는 양식 입력 필드 구조를 JSON으로 저장하고, approval_forms.template_html 에는 웹 에디터에 렌더링할 빈 문서 서식을 저장한다. approval_documents.document_data 에는 기안자가 실제 입력한 값을 JSON으로 저장하고, approval_documents.content 에는 template_html과 document_data를 병합한 뒤 XSS 필터링을 거친 최종 HTML 스냅샷을 저장한다. 자주 검색하거나 집계해야 하는 필드, 예를 들어 금액, 기간, 문서 유형, 위험도 등은 별도 컬럼 또는 인덱스로 분리한다.

8. API 명세

8.1 API 응답 규칙

본 시스템의 API는 성공 응답과 에러 응답을 다음 형식으로 통일하여 클라이언트의 예외 처리를 돕는다.

성공 응답 형식

```

1 {
2   "data": {
3     "id": 55,
4     "status": "IN_PROGRESS"
5   },
6   "message": "요청이 성공적으로 처리되었습니다."
7 }
```

에러 응답 형식

```

1 {
2   "status": 400,
3   "code": "APPROVER_REQUIRED",
4   "message": "결재자는 최소 1명 이상 지정해야 합니다.",
5   "trace_id": "req-20260504-0001"
6 }

```

항목	설명
status	HTTP 상태 코드
code	시스템 내부 도메인 에러 코드
message	사용자에게 표시할 메시지
trace_id	로그 추적용 요청 ID

즉, 400, 403, 409 같은 값은 **HTTP 상태 코드**이고, APPROVER_REQUIRED, ALREADY_VIEWED 같은 값은 **도메인 에러 코드**이다.

8.2 HTTP 상태 코드 사용 기준

HTTP Status	의미	사용 상황
200 OK	조회, 수정, 승인, 반려 성공	상세 조회, 승인, 반려, 수정
201 Created	리소스 생성 성공	문서 상신, 양식 생성, 리스크 기준 생성
202 Accepted	부분 성공 / 비동기 대기	문서 저장은 성공했으나, 알림 발송 등 외부 연동이 지연되어 큐(Queue)에서 대기 중일 때
400 Bad Request	요청값 오류	필수값 누락, 형식 오류, 반려 사유 미입력
401 Unauthorized	인증 필요	로그인하지 않은 사용자
403 Forbidden	권한 없음	현재 결재자 아님, 다른 부서 양식 수정
404 Not Found	리소스 없음	존재하지 않는 문서, 양식, 부서
409 Conflict	현재 상태와 충돌	이미 열람됨, 이미 승인됨, 중복 승인

422 Unprocessable Entity	비즈니스 규칙 위반	고위험 문서 본문 미확인, 필수 결재 단계 누락, 고위험 문서 일괄 결재 시도
428 Precondition Required	사전 조건 필요	승인을 위한 2FA 재인증 필요 시
500 Internal Server Error	서버 내부 오류	DB 저장 실패 등 예기치 못한 내부 서버 오류
503 Service Unavailable	외부 시스템 연동 오류	동기식으로 호출되는 외부 API(일부 OCR 등) 장애 시

8.3 API 목록

No	Method	Endpoint	설명	관련 유스케이스
1	POST	/api/v1/auth/login	로그인	공통
2	GET	/api/v1/approval-forms	사용 가능한 결재 양식 목록 조회	UC-DOC-01
3	GET	/api/v1/approval-forms/{formId}	결재 양식 상세 서식 및 결재선 템플릿 통합 조회	UC-DOC-01
4	POST	/api/v1/approval-documents	결재 문서 작성 및 상신	UC-DOC-01
5	PATCH	/api/v1/approval-documents/{documentId}	상신 후 즉시 수정	UC-DOC-02
6	PATCH	/api/v1/approval-documents/{documentId}/withdraw	문서 회수	UC-DOC-02

7	GET	/api/v1/approval-documents/{documentId}	결재 문서 상세 조회	UC-APP-01, UC-APP-02
8	PATCH	/api/v1/approval-documents/{documentId}/approve	단일 결재 승인	UC-APP-01
9	POST	/api/v1/approval-documents/batch-approve	일괄 결재 승인 (배열 형태의 다중 ID 처리)	UC-APP-01
10	PATCH	/api/v1/approval-documents/{documentId}/reject	결재 반려	UC-APP-02
11	GET	/api/v1/approval-documents	문서함 조회 및 검색	공통
12	POST	/api/v1/departments/{departmentId}/approval-forms	부서별 결재 양식 생성	UC-ADMIN-01
13	POST	/api/v1/departments/{departmentId}/approval-forms/{formId}/risk-rules	부서별 리스크 기준 등록	UC-ADMIN-01
14	POST	/api/v1/departments/{departmentId}/approval-	부서별 결재선 템플릿 등록	UC-ADMIN-01

		forms/{formId }/approval- line- templates		
15	POST	/api/v1/attac hments	결재 문서 첨부파 일 업로드 (문서 상 신 전 선행 호출)	UC-DOC-01, UC- DOC-02

8.4 API 상세 명세

[공통 시스템 예외]

시스템 전반에 걸쳐 공통적으로 발생할 수 있는 보안 인증 및 인프라 장애 관련 예외를 비즈니스 로직과 분리하여 정의함으로써, 설계의 일관성과 유지보수성을 확보합니다.

HTTP Status	Code	유스케이스 예외	Message
401	UNAUTHORIZED	-	인증 토큰이 없거나 만료되었습니다.
500	INTERNAL_SERVER_ERROR	-	서버 내부 오류가 발생했습니다. 관리자에게 문의하세요.
500	SAVE_FAILED	-	데이터 저장 처리 중 시스템 오류가 발생했습니다.
503	SERVICE_UNAVAILABLE	-	외부 서비스(알림, 메일 등) 연동이 일시적으로 지연되고 있습니다.

[API 상세 명세]

(1) 로그인

POST /api/v1/auth/login

항목	내용
----	----

설명	이메일과 비밀번호로 로그인
인증	불필요
관련 유스케이스	공통

Request Body

```

1 {
2   "email": "user@company.com",
3   "password": "password123!"
4 }
```

Response 200 OK

```

1 {
2   "data": {
3     "access_token": "access-token",
4     "refresh_token": "refresh-token",
5     "requires_second_factor": false,
6     "user": {
7       "id": 1,
8       "name": "박도윤",
9       "department_id": 10,
10      "position": "대리",
11      "role_code": "USER"
12    }
13  },
14  "message": "로그인되었습니다."
15 }
```

Error Responses

HTTP Status	Code	Message
400	INVALID_EMAIL_FORMAT	이메일 형식을 확인하세요.
401	INVALID_CREDENTIALS	이메일 또는 비밀번호가 올바르지 않습니다.
423	ACCOUNT_LOCKED	계정이 잠금 처리되었습니다. 관리자에게 문의하세요.

(2) 결재 양식 목록 조회

GET /api/v1/approval-forms

항목	내용
설명	사용 가능한 결재 양식 목록 조회

인증	Bearer Token
관련 유스케이스	UC-DOC-01

Query Parameters

이름	타입	필수	설명
department_id	BIGINT	선택	특정 부서의 양식만 조회
active_only	BOOLEAN	선택	사용 중인 양식만 조회

Response 200 OK

```
1 {
2   "data": [
3     {
4       "id": 3,
5       "department_id": 10,
6       "name": "장비 구매 요청서",
7       "description": "개발팀 장비 구매 결재 양식",
8       "risk_default": "NORMAL",
9       "is_active": true
10    }
11  ],
12  "message": "결재 양식 목록을 조회했습니다."
13 }
```

Error Responses

HTTP Status	Code	Message
403	FORBIDDEN_DEPARTMENT	해당 부서의 양식을 조회할 권한이 없습니다.

(3) 결재 양식 상세 서식 및 결재선 템플릿 통합 조회

GET /api/v1/approval-forms/{formId}

피드백 - 기존 '결재선 템플릿 조회'의 구조를 확장하여 화면 렌더링을 위한 HTML 디자인 서식과 데이터 구조 (Schema)를 한 번에 내려주도록 개정

항목	내용
설명	선택한 양식에 연결된 웹 에디터용 HTML 서식, 데이터 스키마 및 직위·직책 기반 결재선 자동 매핑 정

	보를 통합 조회
인증	Bearer Token
관련 유스케이스	UC-DOC-01

Path Parameters

이름	타입	설명
formId	BIGINT	결재 양식 ID

Response 200 OK

```
1 {
2   "data": {
3     "form_id": 3,
4     "name": "장비 구매 요청서",
5     "template_html": "<div class='form-container'><h1>장비 구매 요청서</h1>",
6     "form_schema": {
7       "fields": [
8         {"name": "item_name", "type": "string", "label": "구매품목", "required": true},
9         {"name": "amount", "type": "number", "label": "금액", "required": true}
10      ]
11    },
12    "template_lines": [
13      {
14        "id": 15,
15        "step_order": 1,
16        "line_type": "APPROVER",
17        "approval_method": "SEQUENTIAL",
18        "required_position": "팀장",
19        "required_job_title": "부서 책임자",
20        "is_required": true,
21        "mapped_user": {
22          "id": 7,
23          "name": "김기훈",
24          "department_id": 10
25        }
26      }
27    ]
28  },
29  "message": "결재 양식 상세 및 템플릿 정보를 조회했습니다."
30 }
```

Error Responses

HTTP Status	Code	유스케이스 예외	Message
404	FORM_NOT_FOUND	-	결재 양식을 찾을 수 없습니다.
422	TEMPLATE_MAPPING_FAILED	UC-DOC-01 E3	일부 결재 역할에 매핑된 사용자가 없습니다.

(4) 결재 문서 작성 및 상신

POST /api/v1/approval-documents

항목	내용
설명	구조화된 비즈니스 데이터와 웹 에디터 렌더링 본문을 분리하여 결재 문서를 상신 (서버 진입 시 XSS 필터링 어댑터 통과)
인증	Bearer Token
관련 유스케이스	UC-DOC-01

Request Body

```
1 {
2   "form_id": 3,
3   "title": "신규 장비 구매 요청",
4   "content": "<table class='company-table'><tr><td>품명</td><td>개발용 노
5   "document_data": {
6     "total_amount": 5000000,
7     "target_department": "개발팀"
8   },
9   "risk_level": "NORMAL",
10  "approval_lines": [
11    {
12      "approver_id": 7,
13      "line_type": "APPROVER",
14      "step_order": 1,
15      "approval_method": "SEQUENTIAL"
16    }
17  ],
18  "attachment_ids": [101]
19 }
```

Response 201 Created

```
1 {
2   "data": {
3     "id": 55,
4     "document_no": "APP-2026-00055",
5     "status": "IN_PROGRESS",
6     "current_step": 1,
7     "security_check": {
8       "xss_sanitized": true,
9       "sanitized_at": "2026-05-16T12:25:10"
10    }
11  },
12  "message": "결재 문서가 안전하게 검증 및 상신되었습니다."
13 }
```

Error Responses

HTTP Status	Code	유스케이스 예외	Message
-------------	------	----------	---------

400	APPROVER_REQUIRE D	UC-DOC-01 E1	결재자는 최소 1명 이상 지정해야 합니다.
400	DUPLICATE_APPROVE R	UC-DOC-01 E2	동일 사용자를 동일 역할에 중복 지정할 수 없습니다.
422	INVALID_APPROVER_ROLE	UC-DOC-01 E4	해당 사용자는 결재자로 지정할 권한이 없습니다.
400	INVALID_SECURITY_CONTENT	UC-DOC-01 E5	허용되지 않는 악성 스크립트나 태그가 포함되어 있습니다.

(5) 상신 후 즉시 수정

PATCH /api/v1/approval-documents/{documentId}

항목	내용
설명	다음 결재자 열람 전, 본문 입력 데이터(JSON)와 렌더링 서식(HTML)을 안전하게 즉시 수정
인증	Bearer Token
관련 유스케이스	UC-DOC-02

Request Body

```
1 {
2   "title": "신규 장비 구매 요청서 (수정)",
3   "document_data": {
4     "item_name": "개발용 고성능 노트북 2대",
5     "amount": 5000000
6   },
7   "content": "<table class='editor-table'><tr><td>품목</td><td>개발용 고성능 노트북 2대</td></tr></table>",
8   "change_reason": "수량 기입 오타 수정",
9   "attachment_ids": [101, 102]
10 }
```

Response 200 OK

```
1 {
2   "data": {
3     "id": 55,
4     "version": 2,
5     "status": "IN_PROGRESS",
6     "document_data": {
```

```

7       "item_name": "개발용 고성능 노트북 2대",
8       "amount": 5000000
9     }
10    },
11    "message": "문서가 수정되었습니다."
12  }

```

Error Responses

HTTP Status	Code	유스케이스 예외	Message
403	FORBIDDEN_DOCUMENT_OWNER	UC-DOC-02 E4	문서 작성자만 수정할 수 있습니다.
404	DOCUMENT_NOT_FOUND	-	결재 문서를 찾을 수 없습니다.
409	ALREADY_VIEWED	UC-DOC-02 E1	다음 결재자가 이미 열람하여 즉시 수정할 수 없습니다.

(6) 결재 문서 회수

PATCH /api/v1/approval-documents/{documentId}/withdraw

항목	내용
설명	최종 승인 전 문서 회수
인증	Bearer Token
관련 유스케이스	UC-DOC-02

Request Body

```

1  {
2    "reason": "첨부파일 오류로 인한 회수"
3  }

```

Response 200 OK

```

1  {
2    "data": {
3      "action_id": 101,
4      "document_id": 55,
5      "status": "WITHDRAWN"
6    },
7    "message": "문서가 회수되었습니다."
8  }

```

Error Responses

HTTP Status	Code	유스케이스 예외	Message
400	WITHDRAW_REASON_REQUIRED	UC-DOC-02 E2	회수 사유를 입력해야 합니다.
403	FORBIDDEN_DOCUMENT_OWNER	UC-DOC-02 E4	문서 작성자만 회수할 수 있습니다.
404	DOCUMENT_NOT_FOUND	-	결재 문서를 찾을 수 없습니다.
409	ALREADY_APPROVED	UC-DOC-02 E3	최종 승인된 문서는 회수할 수 없습니다.

(7) 결재 문서 상세 조회

GET /api/v1/approval-documents/{documentId}

피드백 - 화면 구현(UI/UX) 시 서식이 깨지지 않고 데이터를 원활히 소통하기 위해 메타데이터(JSON)와 본문(HTML)을 명확히 분리 제공

항목	내용
설명	결재 문서의 상세 메타데이터, 구조화된 입력값 (JSON), 보안 검증이 완료된 HTML 본문 스냅샷을 통합 조회
인증	Bearer Token
관련 유스케이스	UC-APP-01, UC-APP-02

Response 200 OK

```
1 {
2   "data": {
3     "id": 55,
4     "document_no": "APP-2026-00055",
5     "title": "신규 장비 구매 요청",
6     "status": "IN_PROGRESS",
7     "risk_level": "HIGH",
8     "document_data": {
9       "item_name": "개발용 고성능 노트북",
10      "amount": 2500000
11    },
12    "content": "<table class='editor-table'>...XSS 정제가 완료된 안전한 HT
13    "approval_lines": [
14      {
```



```

15         "id": 200,
16         "approver_id": 7,
17         "step_order": 1,
18         "line_type": "APPROVER",
19         "approval_method": "SEQUENTIAL",
20         "status": "WAITING"
21     }
22 ]
23 },
24 "message": "결재 문서를 성공적으로 조회했습니다."
25 }

```

Error Responses

HTTP Status	Code	Message
403	FORBIDDEN_DOCUMENT	해당 문서에 접근할 권한이 없습니다.
404	DOCUMENT_NOT_FOUND	결재 문서를 찾을 수 없습니다.

(8) 단일 결재 승인

PATCH `/api/v1/approval-documents/{documentId}/approve`

항목	내용
설명	결재 문서 단일 승인 (전결 옵션 포함)
인증	Bearer Token
관련 유스케이스	UC-APP-01

Request Body

```

1 {
2   "auth_required": true,
3   "auth_result": "SUCCESS",
4   "action_type": "APPROVE"
5 }

```

Response 200 OK

```

1 {
2   "data": {
3     "action_id": 102,
4     "document_id": 55,
5     "status": "IN_PROGRESS",
6     "next_step": 2
7   },
8   "message": "승인되었습니다."
9 }

```

마지막 결재자 승인 시 Response 200 OK

```
1 {
2   "data": {
3     "id": 55,
4     "status": "APPROVED",
5     "completed_at": "2026-05-04T15:30:00"
6   },
7   "message": "최종 승인되었습니다."
8 }
```

Error Responses

HTTP Status	Code	유스케이스 예외	Message
403	NOT_CURRENT_APPROVER	UC-APP-01 E1	현재 결재 순서의 사용 자가 아닙니다.
409	ALREADY_PROCESSED	UC-APP-01 E2	이미 처리된 결재 단계 입니다.
422	HIGH_RISK_CONTENT_NOT_CHECKED	UC-APP-01 E3	고위험 문서는 본문 핵 심 내용을 확인해야 승 인할 수 있습니다.
428	REAUTH_REQUIRED	UC-APP-01 E4	승인을 위해 재인증이 필요합니다.
409	AGREEMENT_PENDING	UC-APP-01 E5	미처리 합의자가 있어 최종 승인할 수 없습니 다.

(9) 일괄 결재 승인 (배열 형태의 다중 ID 처리)

POST /api/v1/approval-documents/batch-approve

항목	내용
설명	여러 개의 일반 결재 문서를 한 번에 승인
인증	Bearer Token
관련 유스케이스	UC-APP-01

Request Body

```
1 {
2   "document_ids": [55, 56, 58]
```

```
3 }
```

Response 200 OK

```
1 {  
2   "data": {  
3     "approved_count": 3  
4   },  
5   "message": "선택한 항목이 모두 승인되었습니다."  
6 }
```

Error Responses

HTTP Status	Code	유스케이스 예외	Message
403	NOT_CURRENT_APPROVER	UC-APP-01 E1	권한이 없거나 현재 결재 순서가 아닌 문서가 포함되어 있습니다.
422	HIGH_RISK_DOCUMENT_INCLUDED	UC-APP-01 E6	고위험 문서는 일괄 결재할 수 없습니다. 개별 확인 후 승인해주세요.
428	REAUTH_REQUIRED	UC-APP-01 E4	승인을 위해 재인증이 필요합니다.

(10) 결재 반려

PATCH /api/v1/approval-documents/{documentId}/reject

항목	내용
설명	결재 문서 반려
인증	Bearer Token
관련 유스케이스	UC-APP-02

Request Body

```
1 {  
2   "reject_target": "WRITER",  
3   "reason": "예산 산정 근거가 부족하여 보완이 필요합니다."  
4 }
```

Response 200 OK

```
1 {  
2   "data": {  
3     "action_id": 103,  
4   },  
5   "message": "결재 반려가 완료되었습니다."  
6 }
```

```

4     "document_id": 55,
5     "status": "REJECTED"
6   },
7   "message": "문서가 반려되었습니다."
8 }

```

Error Responses

HTTP Status	Code	유스케이스 예외	Message
400	REJECT_REASON_REQUESTED	UC-APP-02 E1	반려 사유를 입력해야 합니다.
400	REJECT_REASON_TOO_SHORT	UC-APP-02 E2	반려 사유는 10자 이상 입력해야 합니다.
403	NOT_CURRENT_APPROVER	UC-APP-02 E3	현재 결재 순서의 사용자가 아닙니다.
409	DOCUMENT_ALREADY_COMPLETED	UC-APP-02 E4	이미 완료된 문서는 반려할 수 없습니다.

(11) 문서함 조회 및 검색

GET /api/v1/approval-documents

항목	내용
설명	문서함 목록 조회 및 검색
인증	Bearer Token
관련 유스케이스	공통

Query Parameters

이름	타입	필수	설명
box_type	STRING	선택	MY_DRAFT / APPROVAL / SHARED / CUSTOM
status	STRING	선택	DRAFT / IN_PROGRESS / APPROVED /

			REJECTED / WITHDRAWN
keyword	STRING	선택	제목, 본문, 기안자, OCR 텍스트 검색어
page	INT	선택	페이지 번호
size	INT	선택	페이지 크기

Response 200 OK

```
1 {
2   "data": {
3     "content": [
4       {
5         "id": 55,
6         "document_no": "APP-2026-00055",
7         "title": "신규 장비 구매 요청",
8         "writer_name": "박도윤",
9         "status": "IN_PROGRESS",
10        "current_approver_name": "김기훈",
11        "created_at": "2026-05-04T10:00:00"
12      }
13    ],
14    "page": 0,
15    "size": 20,
16    "total_elements": 1
17  },
18  "message": "문서 목록을 조회했습니다."
19 }
```

Error Responses

HTTP Status	Code	Message
400	INVALID_SEARCH_CONDITION	검색 조건이 올바르지 않습니다.
401	UNAUTHORIZED	인증이 필요합니다.
403	FORBIDDEN_DOCUMENT_BOX	해당 문서함에 접근할 권한이 없습니다.

(12) 부서별 결재 양식 생성

POST /api/v1/departments/{departmentId}/approval-forms

피드백 - 부서 관리자가 관리 화면에서 양식 디자인(`template_html`)과 입력받을 데이터 필드 (`form_schema`)를 함께 등록하도록 명세화하여 프론트-백엔드 간 책임과 소통을 명확히 함

항목	내용
설명	부서 관리자가 해당 부서 소관의 웹 에디터 레이아웃 서식(HTML)과 세부 입력 필드 제약 조건(JSON)을 설계하여 신규 생성
인증	Bearer Token
관련 유스케이스	UC-ADMIN-01

Request Body

```
1  {
2    "name": "장비 구매 요청서",
3    "description": "개발팀 장비 구매 전용 결재 양식 서식",
4    "template_html": "<div class='form-wrapper'><h1>장비 구매 요청서</h1><ta
5    "form_schema": {
6      "fields": [
7        {"name": "item_name", "type": "string", "label": "구매품목", "requ
8        {"name": "amount", "type": "number", "label": "금액", "required":
9      ]
10   },
11   "risk_default": "NORMAL",
12   "is_active": true,
13   "risk_rules": [
14     {
15       "condition_type": "AMOUNT",
16       "condition_operator": "GREATER_THAN",
17       "condition_value": "1000000",
18       "risk_level": "HIGH"
19     }
20   ],
21   "template_lines": [
22     {
23       "step_order": 1,
24       "line_type": "APPROVER",
25       "required_position": "팀장",
26       "required_job_title": "부서 책임자",
27       "approval_method": "SEQUENTIAL",
28       "is_required": true
29     }
30   ]
31 }
```

Response 201 Created

```
1  {
2    "data": {
3      "form_id": 3,
4      "name": "장비 구매 요청서",
5      "risk_default": "NORMAL",
6      "is_active": true
7    },
8    "message": "결재 양식, 리스크 기준, 결재선 템플릿이 성공적으로 통합 등록되었습니다"
9  }
```

Error Responses

HTTP Status	Code	유스케이스 예외	Message
-------------	------	----------	---------

403	DEPARTMENT_ADMIN_REQUIRED	UC-ADMIN-01 E1	해당 부서의 관리자만 결재 양식을 생성할 수 있습니다.
403	FORBIDDEN_DEPARTMENT_FORM	UC-ADMIN-01 E2	해당 부서 양식을 수정할 권한이 없습니다.
400	FORM_NAME_REQUIRED	-	양식명을 입력해야 합니다.
409	DUPLICATE_FORM_NAME	-	동일한 이름의 결재 양식이 이미 존재합니다.

(13) 부서별 리스크 기준 등록

POST /api/v1/departments/{departmentId}/approval-forms/{formId}/risk-rules

항목	내용
설명	부서 관리자가 양식별 고위험 기준 등록
인증	Bearer Token
관련 유스케이스	UC-ADMIN-01

Request Body

```

1 {
2   "condition_type": "AMOUNT",
3   "condition_operator": "GREATER_THAN",
4   "condition_value": "1000000",
5   "risk_level": "HIGH"
6 }
```

Response 201 Created

```

1 {
2   "data": {
3     "id": 12,
4     "form_id": 3,
5     "condition_type": "AMOUNT",
6     "condition_operator": "GREATER_THAN",
7     "condition_value": "1000000",
8     "risk_level": "HIGH"
9   },
10  "message": "리스크 기준이 등록되었습니다."
11 }
```

Error Responses

HTTP Status	Code	유스케이스 예외	Message
403	DEPARTMENT_ADMIN_REQUIRED	UC-ADMIN-01 E1	해당 부서의 관리자만 리스크 기준을 등록할 수 있습니다.
403	FORBIDDEN_DEPARTMENT_FORM	UC-ADMIN-01 E2	다른 부서의 양식에는 리스크 기준을 등록할 수 없습니다.
409	DUPLICATE_RISK_RULE	UC-ADMIN-01 E3	이미 동일한 리스크 기준이 존재합니다.

(14) 부서별 결재선 템플릿 등록

POST /api/v1/departments/{departmentId}/approval-forms/{formId}/approval-line-templates

항목	내용
설명	부서 관리자가 양식에 대한 직위·직책 기반 결재선 템플릿을 등록
인증	Bearer Token
관련 유스케이스	UC-ADMIN-01

Request Body

```

1  {
2    "template_lines": [
3      {
4        "step_order": 1,
5        "line_type": "APPROVER",
6        "required_position": "팀장",
7        "required_job_title": "부서 책임자",
8        "approval_method": "SEQUENTIAL",
9        "is_required": true
10     }
11   ]
12 }
```

Response 201 Created

```

1  {
2    "data": {
3      "form_id": 3,
4      "created_count": 1
5    },
6    "message": "결재선 템플릿이 등록되었습니다."
```


Error Responses

HTTP Status	Code	유스케이스 예외	Message
403	DEPARTMENT_ADMIN_REQUIRED	UC-ADMIN-01 E1	해당 부서의 관리자만 템플릿을 등록할 수 있습니다.
403	FORBIDDEN_DEPARTMENT_FORM	UC-ADMIN-01 E2	다른 부서의 양식에는 템플릿을 등록할 수 없습니다.
422	REQUIRED_TEMP_LATE_STEP_MISsing	UC-ADMIN-01 E4	필수 결재 단계가 누락되었습니다.

(15) 첨부파일 업로드 (상신 전 선행 API로 추가)

POST /api/v1/attachments

항목	내용
설명	문서를 상신하기 전 첨부파일을 서버에 업로드하고 식별자(ID)를 반환받음
인증	Bearer Token
관련 유스케이스	UC-DOC-01, UC-DOC-02

Request (Multipart/form-data)

- file : (Binary Data - 이미지 또는 PDF)

Response 201 Created

```

1 {
2   "data": {
3     "id": 101,
4     "file_name": "견적서.pdf",
5     "file_path": "/uploads/2026/05/견적서.pdf"
6   },
7   "message": "파일이 성공적으로 업로드되었습니다."
8 }

```

Error Responses

HTTP Status	Code	유스케이스 예외	Message
400	INVALID_FILE_FORMAT	공통	지원하지 않는 파일 형식입니다. (이미지 및 PDF만 가능)
413	FILE_TOO_LARGE	공통	파일 크기가 제한을 초과했습니다.

9. 예외 흐름 ↔ HTTP Status ↔ API 에러 코드 ↔ ERD 컬럼 매핑

유스케이스	예외 ID	예외 상황	HTTP Status	API Code	관련 ERD 컬럼
UC-DOC-01	E1	결재자 미지정	400	APPROVER_REQUIRED	approval_lines.approver_id
UC-DOC-01	E2	동일 결재자 중복	400	DUPLICATE_APPROVER	approval_lines.approver_id, approval_lines.step_order
UC-DOC-01	E3	템플릿 매핑 실패	422	TEMPLATE_MAPPING_FAILED	approval_line_templates.required_position, approval_line_templates.required_job_title
UC-DOC-01	E4	권한 없는 결재자 지정	422	INVALID_APPROVER_ROLE	users.position, users.job_title
UC-DOC-01	E5	악성 콘텐츠 포함 (XSS)	400	INVALID_SECURITY_CONTENT	approval_documents.content
UC-DOC-02	E1	다음 결재자 열람 후 수정	409	ALREADY_VIEWED	approval_lines.first_viewed_at
UC-DOC-02	E2	회수 사유 미입력	400	WITHDRAW_REASON_REQUIRED	approval_actions.reason

UC-DOC-02	E3	최종 승인 문서 회수	409	ALREADY_APPROVED	approval_documents.status
UC-DOC-02	E4	기안자가 아닌 사용자 접근	403	FORBIDDEN_DOCUMENT_OWNER	approval_documents.writer_id
UC-APP-01	E1	현재 결재자가 아님	403	NOT_CURRENT_APPROVER	approval_lines.approver_id, approval_documents.current_step
UC-APP-01	E2	중복 승인	409	ALREADY_PROCESSED	approval_lines.status, approval_actions.action_type
UC-APP-01	E3	고위험 문서 본문 미확인	422	HIGH_RISK_CONTENT_NOT_CHECKED	approval_documents.risk_level
UC-APP-01	E4	재인증 필요	428	REAUTH_REQUIRED	approval_actions.auth_required, approval_actions.auth_result
UC-APP-01	E5	미처리 합의자 존재	409	AGREEMENT_PENDING	approval_lines.line_type, approval_lines.status
UC-APP-01	E6	일괄 결재 중 고위험 문서 포함	422	HIGH_RISK_DOCUMENT_INCLUDED	approval_documents.risk_level
UC-APP-02	E1	반려 사유 미입력	400	REJECT_REASON_REQUIRED	approval_actions.reason
UC-APP-02	E2	반려 사유 길이 부족	400	REJECT_REASON_TOO_SHORT	approval_actions.reason
UC-APP-02	E3	현재 결재자가 아님	403	NOT_CURRENT_APPROVER	approval_lines.approver_id

UC-APP-02	E4	완료 문서 반려 시도	409	DOCUMENT_ALREADY_COMPLETED	approval_documents.status
UC-ADMIN-01	E1	부서 관리자 권한 없음	403	DEPARTMENT_ADMIN_REQUIRED	user_roles.role_id, user_roles.department_id
UC-ADMIN-01	E2	다른 부서 양식 수정	403	FORBIDDEN_DEPARTMENT_FORM	approval_forms.department_id
UC-ADMIN-01	E3	중복 리스크 기준	409	DUPLICATE_RISK_RULE	risk_rules.condition_type, risk_rules.condition_value
UC-ADMIN-01	E4	필수 결재 단계 누락	422	REQUIRED_TEMPLATE_STEP_MISSING	approval_line_templates.is_required